

# SAMVEDNA

Evidence-gated stress and welfare intelligence for uniformed forces.

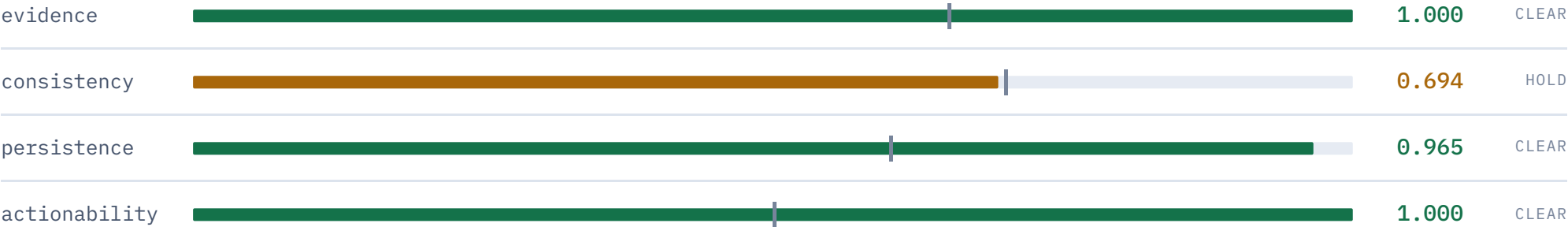
The model raises the concern. The evidence must corroborate it. **The arithmetic decides.** A welfare officer acts.

|           |                                  |
|-----------|----------------------------------|
| TEAM      | CodeZila                         |
| THEME     | MedTech / BioTech / HealthTech   |
| CATEGORY  | Software                         |
| STATE     | Running end to end, on localhost |
| TESTS     | 729 passing                      |
| LANGUAGES | 8 Indian languages               |
| RUNS      | Air-gapped · no GPU · one server |

# The product is the refusal

Every system in this category flags too many people, officers stop trusting it, and personnel learn that answering honestly gets them watched. So this one is built to shut up.

## One real case, refused by 0.006



consistency = mean(0.667, 0.708, 0.708) = 0.694 · needs 0.700

### WHY IT REFUSED

45–61% of this jawan’s unit is deviating the same way, because the unit is deployed. A unit-wide pattern is a **command workload problem**, not an individual welfare concern. Naming this person would have been wrong *and* the fastest way to lose the force’s confidence.

### AND IT SAYS WHAT WOULD CHANGE ITS MIND

“the duty\_roster deviation is still present after the unit’s current deployment cycle ends (op-tempo confounder, 0.70)”

## Data, backend and models

| DECLARED                  | STATUS      | WHERE IT RUNS, AND WHY                                                                                                                                                                      |
|---------------------------|-------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FastAPI · Python          | running     | api/app.py — 21 routes · api/voice_routes.py — 5 more                                                                                                                                       |
| PostgreSQL + TimescaleDB  | seam        | db/store.py — SQLAlchemy 2.0. Same schema on SQLite or Postgres; change one URL. SQLite is the default so the demo travels.                                                                 |
| Apache Airflow            | substituted | pipeline/dag.py — 9 stages with timings, row counts and visible failure. Airflow needs a scheduler, a metadata DB and a webserver; this is one nightly batch, triggered by cron.            |
| Redis                     | substituted | disclosure/dpcache.py — and it is a <b>security control, not a cache</b> : fresh DP noise per refresh averages back to the truth, so a repeated view is served from cache and charged once. |
| XGBoost / LightGBM        | supported   | train_tabular.py --backend auto prefers LightGBM when it <i>loads</i> , falls back to scikit-learn. Default sklearn: LightGBM dies on libomp, which a pendrive copy will not have.          |
| Temporal Transformer      | substituted | models/sequence.py — explicit roster-rhythm features separating <i>predictable</i> from <i>sustainable</i> . torch is ~2 GB and cannot be emailed.                                          |
| Survival analysis         | running     | models/survival.py — discrete-time hazard. Gives a “by when”, which is what makes a case schedulable.                                                                                       |
| SHAP                      | running     | analytics/attribution.py — TreeExplainer, translated into a sentence an officer can repeat aloud.                                                                                           |
| Deterministic gate engine | running     | core/gates.py — pure. An AST test fails the build on I/O, a clock, random or numpy.                                                                                                         |

# Privacy, storage and access

| DECLARED              | STATUS      | WHERE IT RUNS, AND WHY                                                                                                                                        |
|-----------------------|-------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|
| AES-256 + HSM         | AES running | db/crypto.py — AES-256-GCM, one sealed blob per identity, <b>bound to its pid as AAD</b> . HSM is a declared seam that <i>refuses rather than faking it</i> . |
| k-anonymity           | running     | disclosure/kanon.py — $k \geq 5$ , <b>suppress not round</b> .                                                                                                |
| Opacus (DP)           | substituted | ingest/dp.py — calibrated noise, finite $\epsilon$ budget (60 $\epsilon$ ; ~24 $\epsilon$ per unit heat map). Opacus pulls torch.                             |
| Flower (federated)    | substituted | models/federated.py — FedAvg, clip-then-noise ordering. --extra federated installs Flower; the aggregation seam is a Protocol.                                |
| Keycloak RBAC         | substituted | disclosure/rbac.py — 5 roles, purpose binding, unit scope, enforced in the API not the UI. Keycloak issues tokens; <b>the grant table still decides</b> .     |
| Flutter (Android/iOS) | substituted | web/app/manifest.ts — installable PWA. The force hosts it end to end, and there is <b>one consent text</b> rather than three.                                 |
| React + TypeScript    | running     | web/ — React 19, TypeScript, Next.js 15.5.4. Four role consoles.                                                                                              |

9 running · 5 substituted with the seam intact · 2 seams awaiting a deployment · 1 not built. Every substitution is the same constraint: it had to survive being copied onto a pendrive and emailed.

## What is on disk, and what an attacker gets

### IDENTITIES

The only real PII. **AES-256-GCM sealed**, one blob per row, bound to its pid. With the database file an attacker gets pseudonyms and ciphertext.

### LEDGER\_ENTRIES

Hash-chained, **in the clear on purpose**. An audit ledger nobody can read is not an audit ledger — its integrity matters, its confidentiality does not.

### CONSENT\_RECORDS

Keyed by pid, so no identifier. **There is no withdrawn\_at column** — a nullable timestamp is something a dashboard can count.

### Three findings from our own tests

- **A ciphertext moved to another pid** would have disclosed the wrong person — with no key at all. Fixed by binding the pid as additional authenticated data.
- **SQLite's DELETE does not erase**. A purged pid was still greppable out of the file. Now `secure_delete` + `VACUUM`.
- **The write-ahead log still held it** after that. Purge now also runs `wal_checkpoint(TRUNCATE)`. Under the DPDP Act erasure has to mean erasure.

### THE TEST THAT PROVES IT

```
tests/storage/test_secure_store.py::  
test_no_personal_data_appears_in_the_database_file
```

It greps the raw `.db`, `-wal` and `-shm` for the plaintext name, service number and contact — and asserts the pid *is* present, because a scan that finds nothing proves nothing if the row never reached the file. That version of the test nearly shipped.

# What happens when something fails

The governing rule is the opposite of most systems: it fails **towards silence, never towards accusation** — and no fallback is silent.

## Degrades — the run continues, and says so

|                         |                                                                                              |
|-------------------------|----------------------------------------------------------------------------------------------|
| Risk model missing      | Stage 5 degrades. The gates never needed a score. Proven in CI with --model-dir /nonexistent |
| LightGBM won't load     | Falls back to scikit-learn, prints why                                                       |
| HRMS export short       | Domain <b>excluded, never imputed</b> ; data-gap confounder fires; run marked PARTIAL        |
| Export file absent      | unavailable, not ok-with-zero-rows                                                           |
| Malformed row           | Counted and dropped, never coerced                                                           |
| A reviewer times out    | Named in unavailable_reviewers on the case card                                              |
| Model drift exceeds PSI | <b>Escalation freezes entirely</b> until a board reviews                                     |

## Fails closed — no degraded mode, on purpose

|                        |                                                                                                 |
|------------------------|-------------------------------------------------------------------------------------------------|
| Ledger write fails     | The disclosure <b>aborts</b> . No ordering exists in which a name exists without a record of it |
| Encryption key missing | Refuses to start. A store that degrades to plaintext is worse than one that stops               |

# It scales. The caseload does not.

Measured over cohorts from 240 to 4,000 people — 7.6 million records at the top end. Per-person cost *falls* as the cohort grows, so the extrapolation is arithmetic rather than optimism. One commodity server, no GPU, no distributed system, because every person is scored independently of every other.

## GETTING HERE FOUND FOUR QUADRATIC PATHS

Consent scope at enrolment, unit\_of, domains\_for, and the cohort baseline recomputed once per member of the cohort. Before the fixes, per-person cost *grew* from 22 ms to 41 ms. Escalation counts are byte-identical before and after — the fixes changed no decision, and the suite asserts it.

## THE HALF THAT IS NOT GOOD NEWS

The escalation rate is stable near **0.8%**. At 240 people that is 3 cases and a good night's work. At ten lakh it is **~8,200 cases a night** — about 1,370 welfare officers at six conversations each. **That is not a deployable number.**

It is also not a compute problem. It is an operating-point decision, and the dial is exposed and measured:

| EVIDENCE THRESHOLD | RATE   | CASES AT 10 LAKH |
|--------------------|--------|------------------|
| 0.65 (current)     | ~1.20% | ~12,000          |
| 0.70               | ~0.65% | ~6,500           |
| 0.80               | ~0.05% | ~500             |

## Answers we already have

### Q Your deck says LightGBM. Why is scikit-learn installed?

Both. `--backend auto` prefers LightGBM and falls back. Here is the actual reason, from this machine:

```
dlopen(lib_lightgbm.dylib): Library not loaded: @rpath/libomp.dylib
```

The wheel installs cleanly and dies at *load*, because libomp is a separate Homebrew package. That is an `OSError`, not an `ImportError` — so the naive fallback does not catch it, which we found by writing it wrong first. On a provisioned server, `--extra fast` and you get LightGBM.

---

### Q Where is Airflow? Where is Redis?

`pipeline/dag.py` and `disclosure/dpcache.py`. Airflow's value is scheduling many interdependent DAGs across a cluster; this is one nightly batch. What was needed from it — per-stage status, row counts, timings, visible failure — is on the control room screen. Redis would hold the same structure if this ran multi-node; the release cache is a security control, not a speed-up.

---

### Q Flutter was declared. This is a web app.

An installable PWA. Two reasons, and the second is the real one: a store app's binary and update channel sit outside the organisation, and consent is recorded against a **specific text in a specific language at a specific version**. Maintaining that screen three times is three chances for them to disagree about what somebody agreed to.

---

### Q Do you actually have an HSM?

No, and `HsmKeyProvider.key()` raises rather than pretending: *“HSM support is a seam, not an implementation.”* Every module answers a different protocol, and a stub that quietly returned a locally-derived key while calling itself an HSM provider would be the most dangerous class in the codebase.



## Including the ones we would rather be asked

### Q How do I know the demo isn't hardcoded?

`uv run samvedna cohorts` runs all three fixture cohorts through the real engine, and the interesting one **refuses** — by 0.006. A hardcoded demo does not fail by 0.006. `./check.sh` also asserts the fixtures reproduce byte-for-byte from the seed.

---

### Q Which parts are AI, and which parts decide?

**AI:** gradient-boosted risk score, SHAP, survival hazard, roster rhythm, three reviewers. **Decides:** `core/gates.py` — four sums against four thresholds. No model, LLM or heuristic may emit a gate value, a verdict or a confidence. There is no LLM in the decision path and no external endpoint anywhere; the build fails on one.

---

### Q What about false negatives? Everything here is about not over-flagging.

Fair, and it was a real gap. `pipeline/missed.py`: when a concern surfaces through another channel, it is registered with the verdict we had and the gate that declined it — and above a 0.30 missed-case ceiling the loop proposes *loosening*. Before it existed, the system could only ever raise a threshold, which converges on naming nobody. **It is surfaced-case recall, not recall** — a concern nobody ever raised is invisible to it, and that limit is a named constant in the code.

---

### Q What is your biggest weakness?

**There is no real dataset.** The cohort is generated from seed 26186 and the training label is `strain ≥ 0.55`, which is circular — the model learns the generator. The model card is stamped `synthetic: true`. Any accuracy figure from it measures the generator, not the world. Every architectural claim on these slides is testable today; the accuracy claims need an ethics approval and a data-sharing agreement, not an afternoon.

CLOSE ON THIS, NOT ON THE ESCALATION

# It did not stay silent because we told it to.

It stayed silent because the evidence failed the gates — and it told us exactly what would change its mind.

## SEE IT YOURSELF

```
./run.sh  
localhost:3100/demo  
localhost:8090/api-console
```

Four consoles, plus the API console — every route with the role it needs. Switch role, re-send, watch it turn 403. No CDN, so it works on venue wifi that doesn't.

## VERIFY IT YOURSELF

```
./check.sh  
./check.sh --transfer
```

729 tests, L3 purity, portability, packaging — and it unzips into a temp directory and runs cold.

## READ THE LIMITS

```
docs/PS_COMPLIANCE.md  
docs/TECH_STACK.md
```

Every requirement, and every gap, stated rather than buried.

**Welfare support, never disciplinary action. Outputs are barred *in software* from ACR, posting, promotion and disciplinary processes.**